Malware

Viruses, Worms, Trojans, Rootkits

- Malware can be classified into several categories, depending on propagation and concealment
- Propagation
  - Virus: human-assisted propagation (e.g., open email attachment)
  - Worm: automatic propagation without human assistance
- Concealment
  - Rootkit: modifies operating system to hide its existence
  - Trojan: provides desirable functionality but hides malicious operation
- Various types of payloads, ranging from annoyance to crime

Insider Attacks

- A security breach that is caused or facilitated by someone who is a part of the very organization that controls or builds the asset that should be protected.
- In the case of malware, an insider attack refers to a security hole that is created in a software system by one of its programmers.

Backdoors

- A **backdoor / trapdoor** is a hidden feature or command in a program that allows a user to perform actions he or she would not normally be allowed to do.
- When used in a normal way, this program performs completely as expected and advertised.
- But if the hidden feature is activated, the program does something unexpected, often in violation of security policies, such as performing a privilege escalation.

Non-malicious Backdoors

- Some backdoors are put into a program by its programmers
  - Debugging purpose (bypass some tedious steps to speed up debugging)
  - Many computer games have backdoors
    - Secret key code to change gaming role (full health, full map, invincible)

Malicious Backdoors

- Deliberate backdoors inserted by malicious programmers
  - Blackmail, secret previledge
- Backdoor created by malware on compromised machines
  - Open a TCP listening service, anyone can have a shell connection to the machine without account and password
  - Example: Code Red II

Logic Bombs

- A **logic bomb** is a program that performs a malicious action as a result of a certain logic condition.
- The classic example of a logic bomb is a programmer puts in Payroll code that makes the program crash should it ever process two consecutive payrolls without paying him.
- Another classic example combines a logic bomb with a backdoor, where a programmer puts in a logic bomb that will crash the program on a certain date.



The Omega Engineering Logic Bomb

- Logic bomb that was actually triggered and caused damage is one that programmer Tim Lloyd was convicted of using on his former employer,

- On July 31, 1996, a logic bomb was triggered on the server for Omega Engineering's manufacturing operations, which ultimately cost the company millions of dollars in damages and led to it laying off many of its employees.

The Omega Bomb Code

- 7/30/96
  - Event that triggered the bomb
- F:
  - Focused attention to volume F, which had critical files
- F:\LOGIN\LOGIN 12345
  - Login a fictitious user, 12345 (the back door)
- CD \PUBLIC
  - Moves to the public folder of programs
- FIX.EXE /Y F:*.*
  - Run a program, called FIX, which actually deletes everything
- PURGE F:\/ALL
  - Prevent recovery of the deleted files

Defenses against Insider Attacks

- Avoid single points of failure.
- Use code walk-throughs.
- Use archiving and reporting tools.
- Limit authority and permissions.
- Physically secure critical systems.
- Monitor employee behavior.
- Control software installations.

Virus

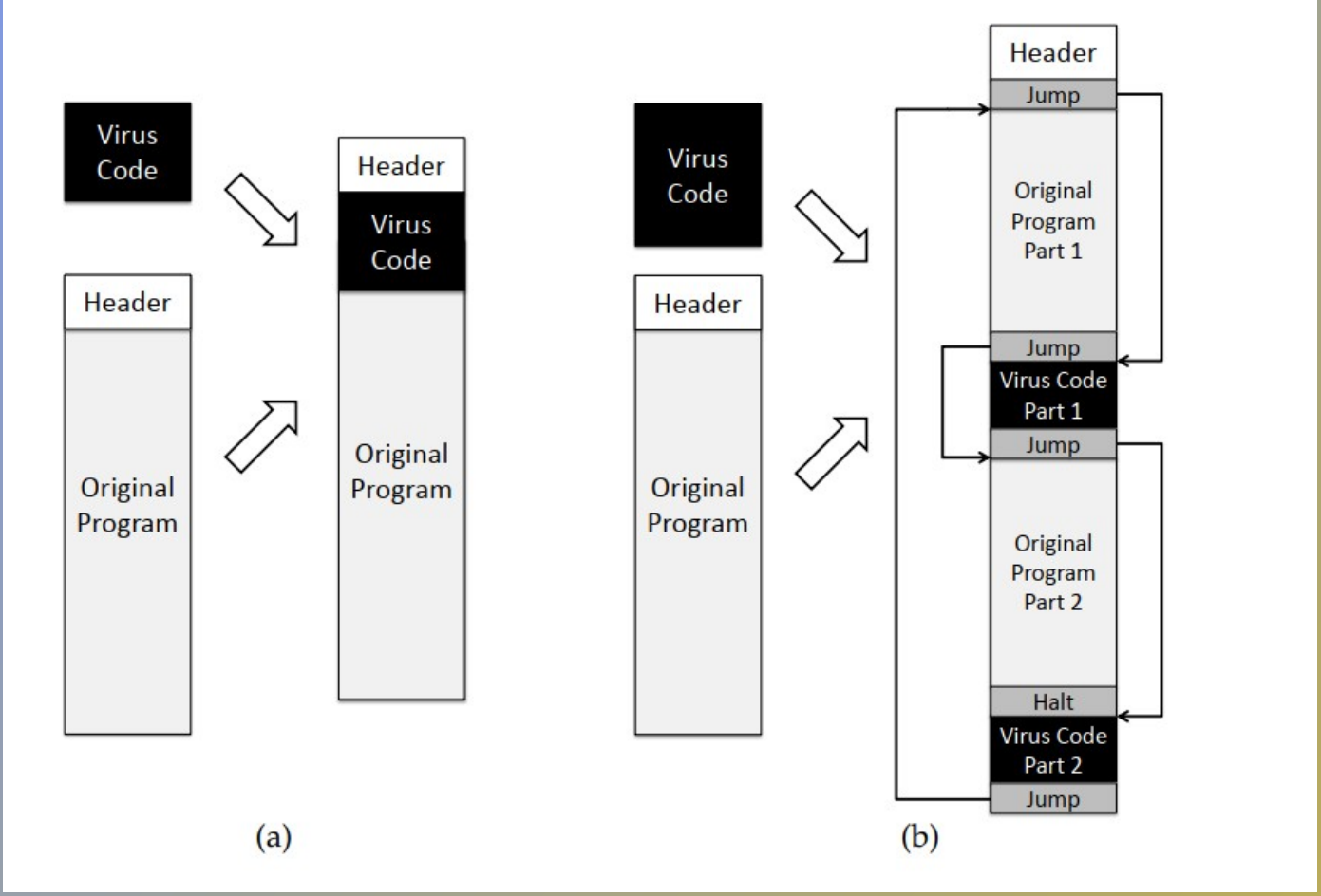
Viruses

- Virus propagates by infecting other programs
  - Automatically creates copies of itself, but to propagate, a human has to run an infected program
    - Self-propagating malicious programs are usually called worms
- Many propagation methods
  - Insert a copy into every executable (.COM, .EXE)
  - Insert a copy into boot sectors of disks
    - "Stoned" virus infected PCs booted from infected floppies, stayed in memory and infected every floppy inserted into PC
  - Infect TSR (terminate-and-stay-resident) routines
    - By infecting a common OS routine, a virus can always stay in memory and infect all disks, executables, etc.

Virus

- A **computer virus** is computer code that can replicate itself by **modifying other files** or programs to insert code that is capable of further replication.
- Replication requires some type of **user assistance,** such as clicking on an email attachment
- This self-replication property is what distinguishes computer viruses from other kinds of malware, such as worm.

Injecting Virus code



Virus Phases

- **Dormant phase.** During this phase, the virus just exists—the virus is laying low and avoiding detection.
- **Propagation phase.** During this phase, the virus is replicating itself, infecting new files on new systems.
- **Triggering phase.** In this phase, some logical condition causes the virus to move from a dormant or propagation phase to perform its intended action.
- **Action phase.** In this phase, the virus performs the malicious action that it was designed to perform, called **payload.**
  - This action could include something seemingly innocent, like displaying a silly picture on a computer's screen, or something quite malicious, such as deleting all essential files on the hard drive.

Virus Techniques

- Macro viruses
  - A macro is an executable program embedded in a word processing document (MS Word) or spreadsheet (Excel)
  - When infected document is opened, virus copies itself into global macro file and makes itself auto-executing (e.g., gets invoked whenever any document is opened)
- Stealth techniques
  - Infect OS so that infected files appear normal
    - Used by rootkits (we'll look at them later)
  - Mutate, encrypt parts of code with random key

Viruses in P2P Networks

- Millions of users willingly download files
- Easy to insert an infected file into the network
  - Pretend to be an executable of a popular application
    - “Adobe Photoshop 10 full.exe”, “WinZip 8.1.exe”, …
- Malware can open backdoor, steal confidential information, spread spam
  - 70% of infected hosts already on DNS spam blacklists

Stealth Techniques

- Mutation: virus has multiple binary variants
  - Defeats naïve signature-based detection
  - Used by the most successful (i.e., widespread) viruses

- Aliasing: virus places its copies under different names into the infected host's sharing folder
  - "ICQ Lite .exe", "ICQ Pro 2003b.exe", "MSN Messenger 5.2.exe"

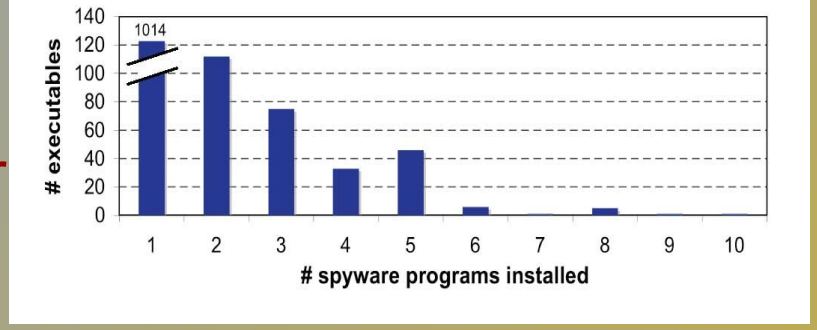
Propagation via Websites

- Websites with popular content
  - Games: 60% of websites contain executable content, one-third contain at least one malicious executable
  - Celebrities, adult content, everything except news
- Large variety of malware
  - But most of the observed programs are variants of the same few adware applications

Malicious Functionality

- Adware
  - Display unwanted pop-up ads
- Browser hijackers
  - Modify home page, search tools, redirect URLs
- Trojan downloaders
  - Download and install additional malware
- Dialer (expensive toll number
- Keylogging

spyware function	May 2005	October 2005
keylogging	0.04%	0.15%
dialer	0.14%	0.9%
Trojan downloader	9.1%	13%
browser hijacker	60%	85%
adware	91%	75%



Drive-By Downloads

- Website "pushes" malicious executable to user's browser with inline Javascript or pop-up window
  - Naïve user may click "**Yes**" in the dialog box
- Can also install malicious software automatically by exploiting bugs in the user's browser
- Constant change
  - Many infectious sites exist only for a short time or change substantially from month to month
  - Many sites behave non-deterministically

Concealment

- Encrypted virus
  - Decryption engine + encrypted body
  - Randomly generate encryption key +brute force decryption
  - Detection looks for decryption engine
- Polymorphic virus
  - Encrypted virus with random variations of the decryption engine (e.g., padding code)
  - Detection using CPU emulator
- Metamorphic virus
  - Different virus bodies
  - Approaches include code permutation and instruction replacement
  - Challenging to detect

Encrypted Viruses

- Encrypted viruses: virus consists of a constant decryptor, followed by the encrypted virus body
  - Relatively easy to detect because decryptor is constant

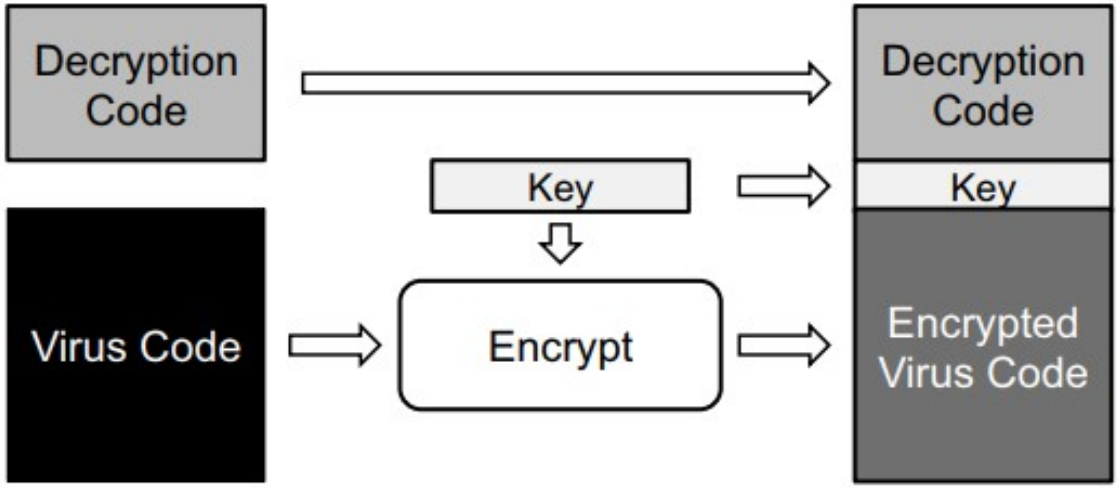
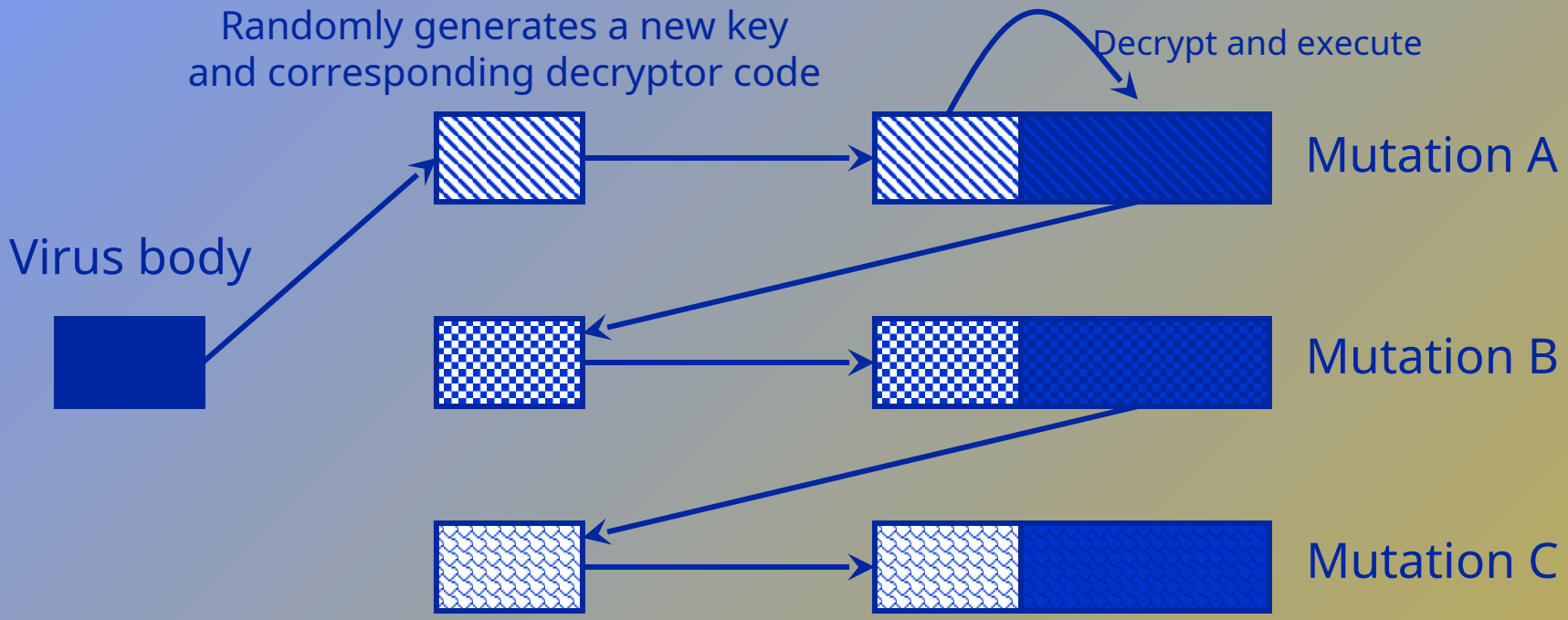


Figure 5: How an encrypted virus is structured.

Polymorphic Viruses

- Polymorphic viruses: constantly create new random encryptions of the same virus body
  - Virus includes an engine for creating new keys and new encryptions of the virus body
    - Crypto (Win32) decrypts its body by brute-force key search to avoid explicit decryptor code
  - Decryptor can start with millions of NOPs to defeat emulation

Virus Detection by Emulation



To detect an unknown mutation of a known virus,

emulate CPU execution of until the current sequence of instruction opcodes matches the known sequence for virus bo

Anti-Virus Technologies

- Simple anti-virus scanners
  - Look for signatures (fragments of known virus code)
  - Heuristics for recognizing code associated with viruses
    - Polymorphic viruses often use decryption loops
  - Integrity checking to find modified files
    - Record file sizes, checksums, MACs (keyed hashes of contents)
    - Often used for rootkit detection
- Generic decryption and emulation
  - Emulate CPU execution for a few hundred instructions, virus will eventually decrypt, can recognize known body
    - Does not work very well against mutating viruses and viruses not located near beginning of infected executable

Metamorphic Viruses

- Obvious next step: mutate the virus body, too!
- Virus can carry its source code (which deliberately contains some useless junk) and recompile itself
  - Virus first looks for an installed compiler
    - Unix machines have C compilers installed by default
  - Virus changes junk in its source and recompiles itself
    - New binary mutation looks completely different!
- Mutation is common in macro and script viruses
  - Macros/scripts are usually interpreted, not compiled

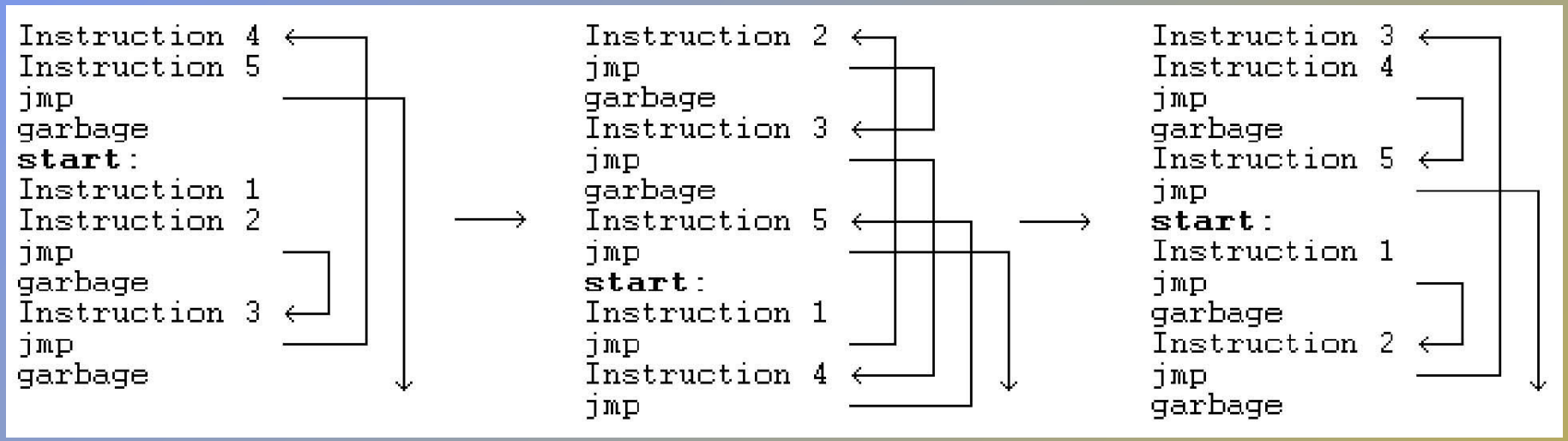
Obfuscation and Anti-Debugging

- Common in worms, viruses, bots
- Goal: prevent analysis of code and signature-based detection; foil reverse-engineering
  - Insert garbage opcodes and change control structure
  - Different code in each instance
    - Effect of code execution is the same, but difficult to detect by passive analysis
  - Packed binaries
- Detect debuggers and virtual machines, terminate execution

Mutation Engines

- Real Permutating Engine/RPME, ADMutate, etc.
- Large set of obfuscating techniques
  - Instructions are reordered, branch conditions reversed
  - Jumps and NOPs inserted in random places
  - Garbage opcodes inserted in unreachable code areas
  - Instruction sequences replaced with other instructions that have the same effect, but different opcodes
    - Mutate SUB EAX, EAX into XOR EAX, EAX or
      PUSH EBP; MOV EBP, ESP into PUSH EBP; PUSH ESP; POP EBP
- There is no constant, recognizable virus body!

Example of Mutation



Worms

Viruses vs. Worms

VIRUS

- Propagates by infecting other programs
- Usually inserted into host code (not a standalone program)

WORM

- Propagates automatically by copying itself to target systems
- Is a standalone program

Sometimes, it is hard to distinguish virus or worm





Morris Worm

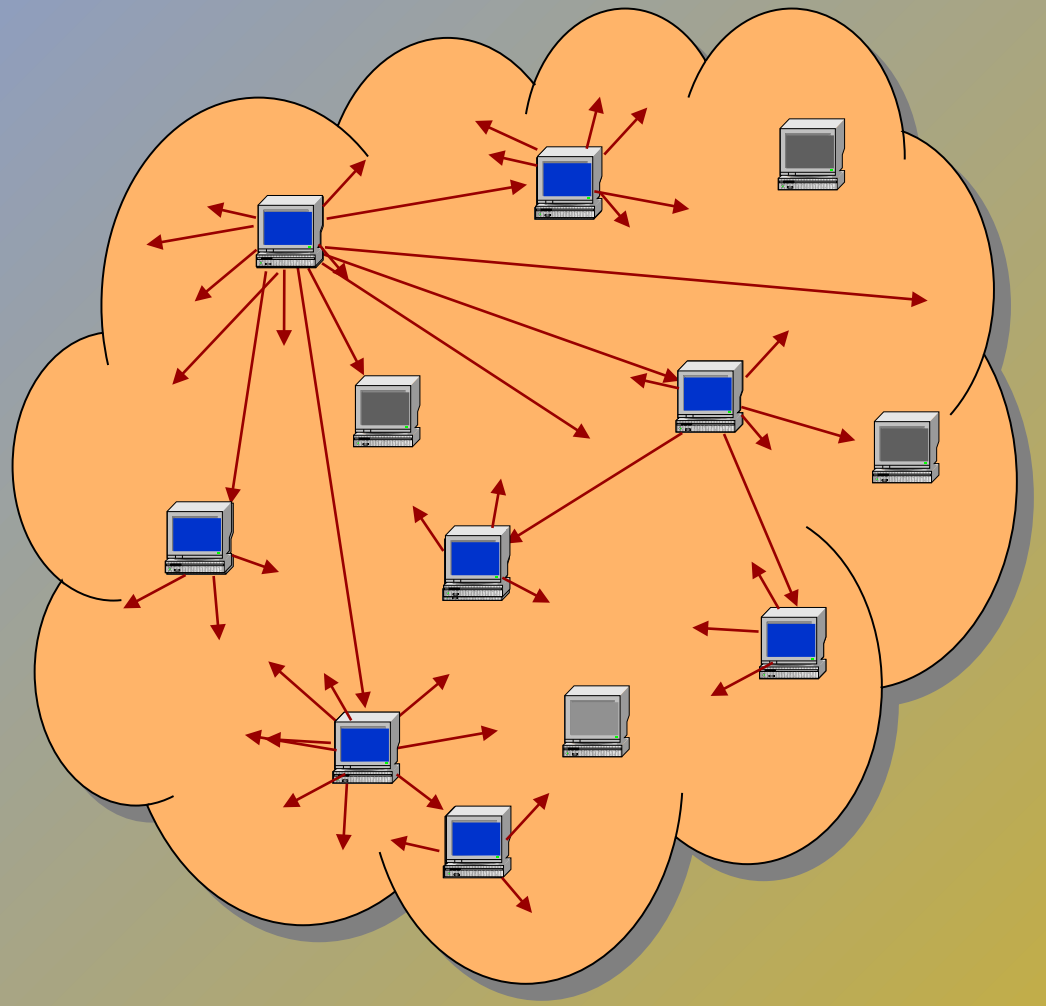
- 1988: No malicious payload, but bogged down infected machines by uncontrolled spawning
  - Infected 10% of all Internet hosts at the time
- Multiple propagation vectors
  - Remote execution using rsh and cracked passwords
    - Tried to crack passwords using small dictionary and publicly readable password file; targeted hosts from /etc/hosts.equiv
  - Buffer overflow in fingerd on VAX
    - Standard stack smashing exploit
  - DEBUG command in Sendmail
    - In early Sendmail versions, possible to execute a command on a remote machine by sending an SMTP (mail transfer) message

Dictionary attack

Buffer overflow attack

Worm propagation process

- Find new targets
  - IP random scanning
- Compromise targets
  - Exploit vulnerability
  - Trick users to run malicious code -- spam
- Newly infected join infection army



Worm research motivation

- Code Red (Jul. 2001)：360,000 infected in 14 hours
- Slammer (Jan. 2003)：75,000 infected in 10 minutes
  Congested parts of Internet (ATMs down…)
- Blaster (Aug. 2003)： 150,000 ~ 8 million infected　DDOS attack (shut down domain windowsupdate.com)
- Witty (Mar. 2004)：12,000 infected in half an hour　Attack vulnerability in ISS security products
- Sasser (May 2004)：500,000 infected within two days
- Storm (Jan 2007): infected 1 to 5 millions computers

- https://en.wikipedia.org/wiki/List_of_computer_worms

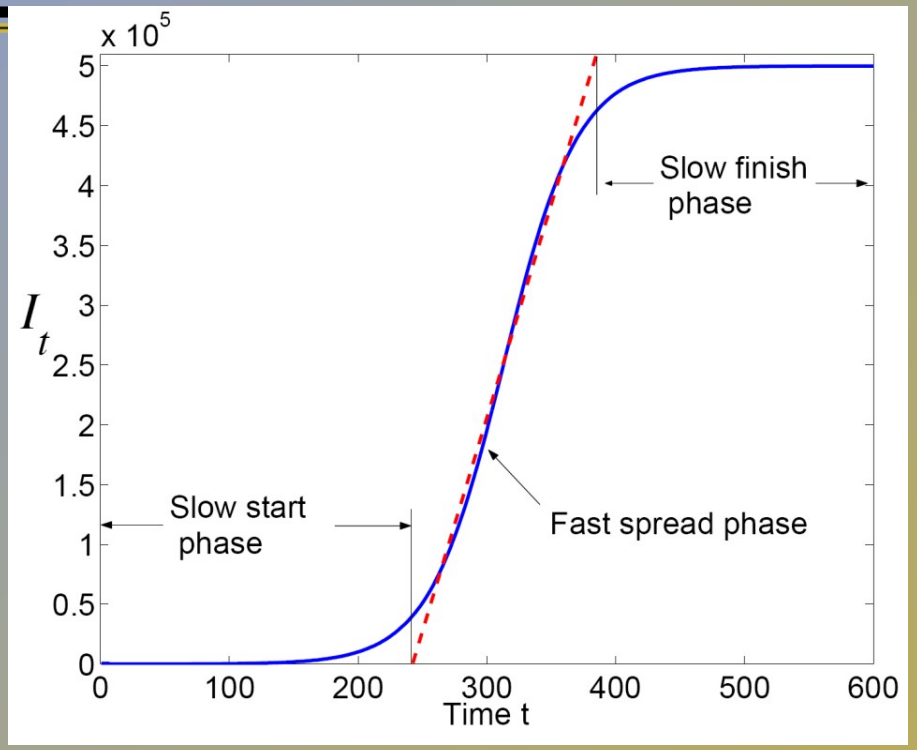
How do worms propagate?

- Scanning worms
  - Worm chooses “random” address
- Coordinated scanning
  - Different worm instances scan different addresses
- Flash worms
  - Assemble tree of vulnerable hosts in advance, propagate along tree
- Meta-server worm
  - Ask server for hosts to infect
- Topological worm:
  - Use information from infected hosts (web server logs, email address books, config files, SSH “known hosts”)
- Contagion worm
  - Propagate parasitically along with normally initiated communication

Propagation: Theory

- Classic epidemic model
  - N: total number of vulnerable hosts
  - $I(t)$: number of infected hosts at time t
  - $S(t)$: number of susceptible hosts at time t
  - $I(t) + S(t) = N$
  - β: infection rate
- Differential equation for $I(t)$:

$$dI/dt = \beta I(t)\, S(t)$$



Signature-Based Defenses Don't Help

- Many firewalls pass mail untouched, relying on mail servers to filter out infections
  - Most filters simply scan attachments for signatures (code snippets) of known viruses and worms
- Nimda was a brand-new infection with unknown signature, and scanners could not detect it
- Big challenge: detection of zero-day attacks
  - When a worm first appears in the wild, signature is not extracted until minutes or hours later

Storm Worm Characteristics

- Infected machine joins botnet
  - Between 1 and 5 million machines infected (Sep 2007)
- Obfuscated peer-to-peer control structure
  - Not like Agobot, which uses simple IRC control channel
  - Interacts with peers via eDonkey protocol
- Obfuscated code, anti-debugging defenses
  - Goes into infinite loop if detects VMware or Virtual PC
  - Large number of spurious probes (evidence of external analysis) triggers distributed DoS attack

4.3 : Botnets

Botnets

- Collection of compromised hosts
  - Spread like worms and viruses
  - Once installed, respond to remote commands
- A network of ‘bots’
- robot :

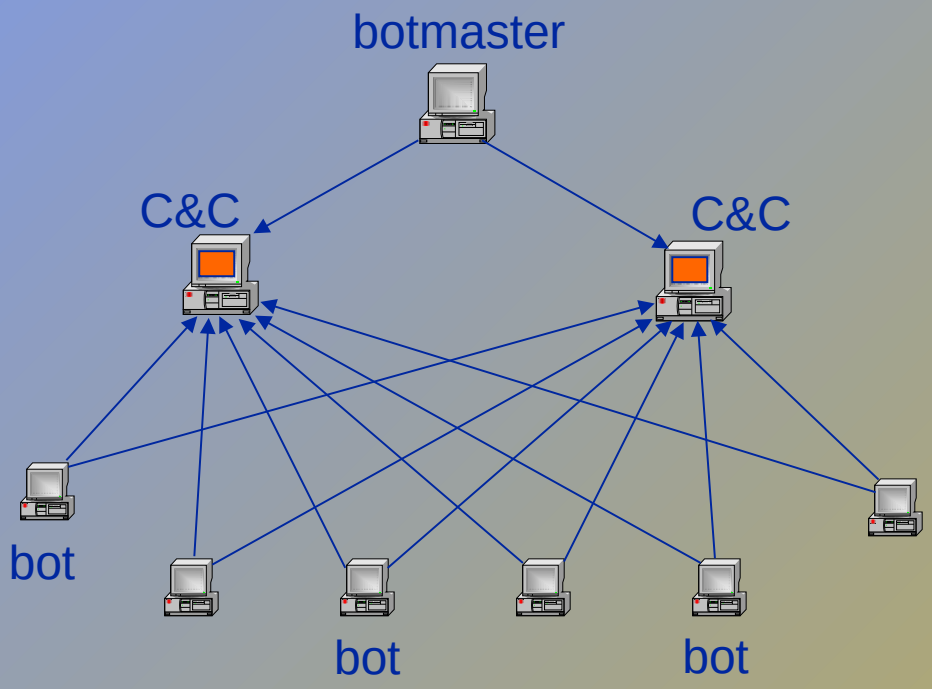
  an automatic machine that can be programmed to perform specific tasks.
- Also known as ‘zombies’



Bot activities

- Platform for many attacks
  - Spam forwarding (70% of all spam?)
  - Click fraud
  - Keystroke logging
  - Distributed denial of service attacks
- Serious problem
  - Top concern of banks, online merchants
  - ¼ of hosts connected to Internet

Current Botnet Control Architecture



- **More than one C&C server**
- **Spread all around the world**

Botnet Monitor: Honeypot Spy

- Security researchers set up honeypots
  - Honeypots: deliberately set up vulnerable machines
  - When compromised, put close monitoring of malware's behaviors
- When compromised honeypot joins a botnet
  - Passive monitoring: log all network traffic
  - Active monitoring: actively contact other bots to obtain more information (neighborhood list, additional c&c, etc.)

The Future Generation of Botnets

- Peer-to-Peer C&C
- Polymorphism
- Anti-honeypot
- Rootkit techniques

Rootkits

The Evolution of Malware

- Malware, including spyware, adware and viruses want to be **hard to detect** and/or hard to remove
- Rootkits are a fast evolving technology to achieve these goals
  - Cloaking technology applied to malware
  - Not malware by itself

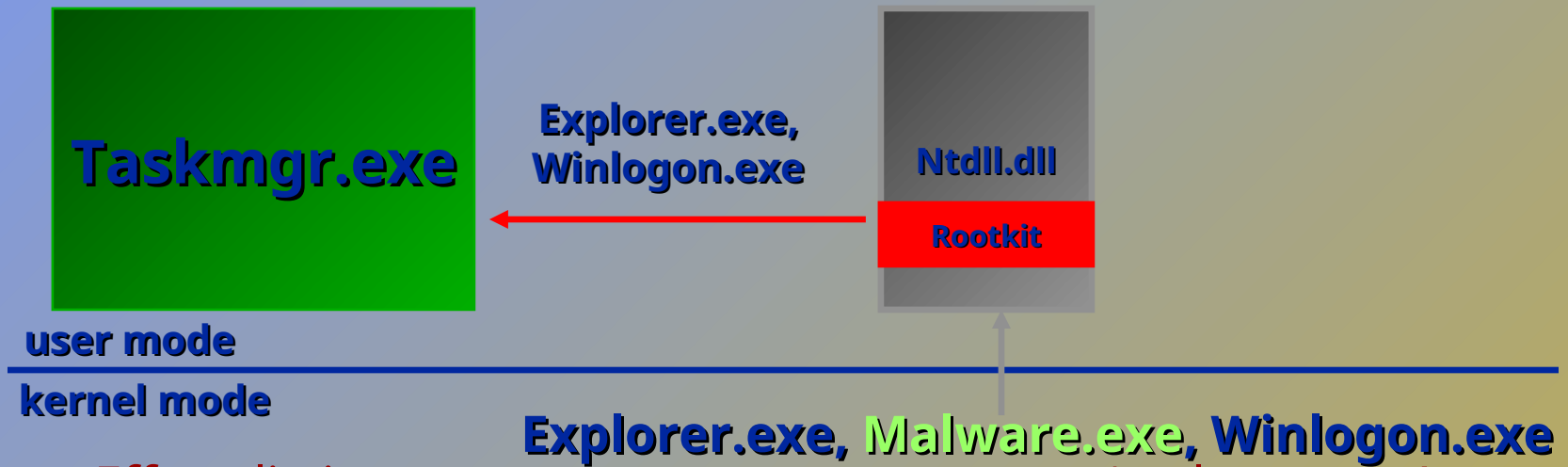
- Rootkit history
  - Appeared as stealth viruses
    - One of the first known PC viruses, Brain, was stealth
  - First “rootkit” appeared on SunOS in 1994
    - Replacement of core system utilities (ls, ps, etc.) to hide malware processes

Cloaking

- Modern rootkits can cloak:
  - Processes
  - Services
  - TCP/IP ports
  - Files
  - Registry keys
  - User accounts
- Several major rootkit technologies
  - User-mode API filtering
  - Kernel-mode API filtering
  - Kernel-mode data structure manipulation
  - Process hijacking

User-Mode API Filtering

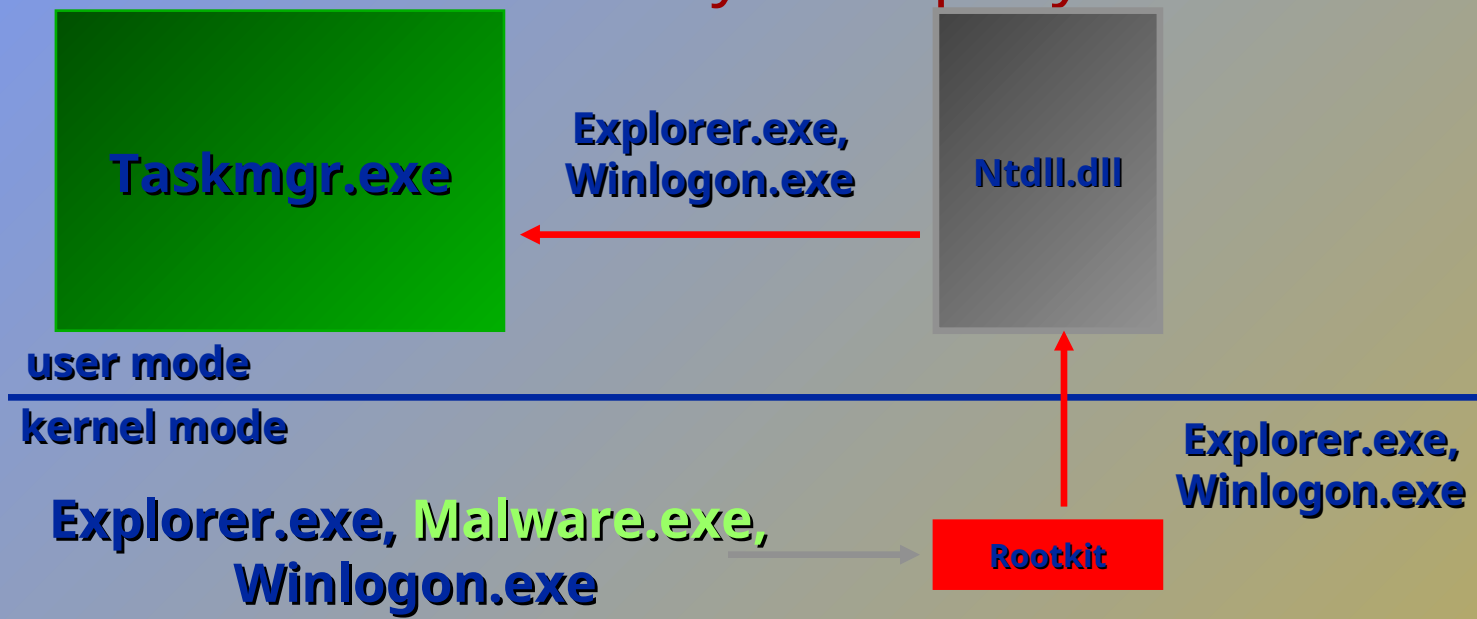
- Attack user-mode system query APIs



- Effect: listing system processes cannot see ‘malware.exe’ running process
- Con: can be bypassed by going directly to kernel-mode APIs
- Pro: can infect unprivileged user accounts
- Examples: HackerDefender, Afx

Kernel-Mode API Filtering

- Attack kernel-mode system query APIs



- Cons:
  - Requires admin privilege to install
  - Difficult to write
- Pro: very thorough cloak
- Example: NT Rootkit

Kernel-Mode Data Structure Manipulation

- Also called Direct Kernel Object Manipulation (DKOM)
- Attacks active process data structure
  - Query API doesn't see the process
  - Kernel still schedules process' threads



- Cons:
  - Requires admin privilege to install
  - Can cause crashes
- Pro: more advanced variations possible

Detecting Rootkits

- All cloaks have holes
  - Leave some APIs unfiltered
  - Have detectable side effects
- Rootkit detection attacks holes
  - Cat-and-mouse game
  - Several examples
    - RKDetect
    - Sysinternals RootkitRevealer

Simple Rootkit Detection

- Perform a directory listing online and **compare with secure alternate OS boot** (see http://research.microsoft.com/rootkit/)
- This won't detect non-persistent rootkits that save to disk during shutdown

Dealing with Rootkits

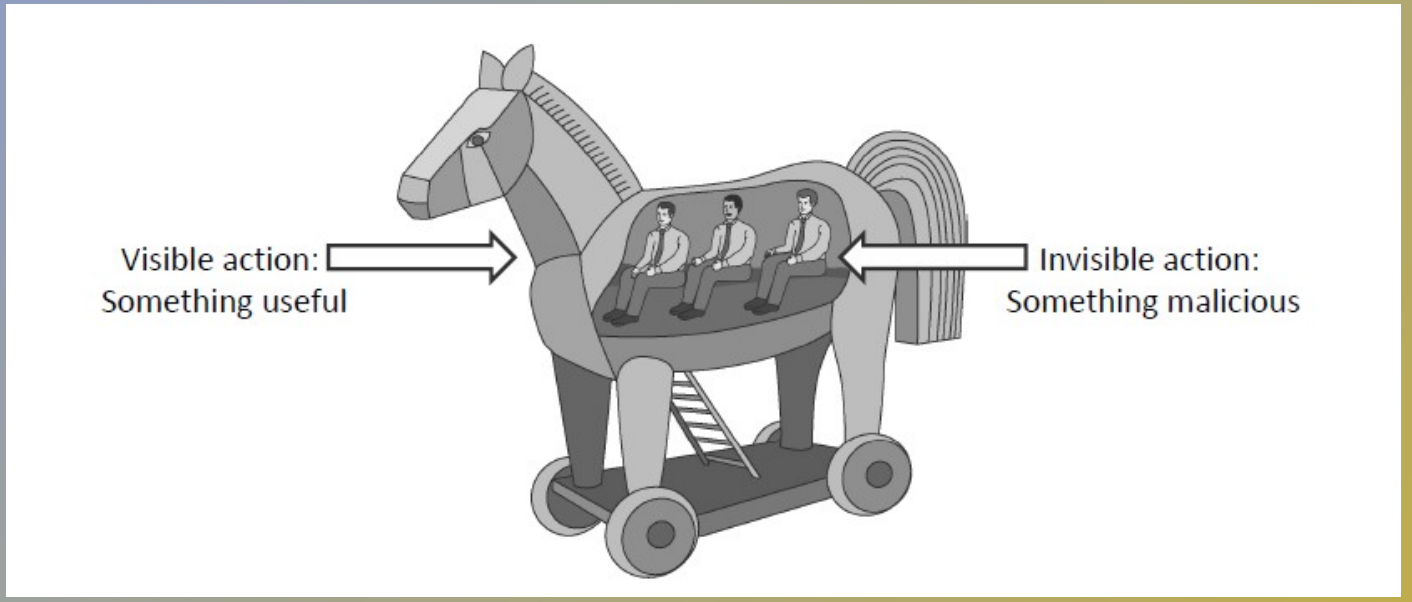
- Unless you have specific uninstall instructions from an authoritative source:

Reformat the system and reinstall Windows!

- Don’t rely on “rename” functionality offered by some rootkit detectors
  - It might not have detected all a rootkit’s components
  - The rename might not be effective

Trojan Horses

- A **Trojan horse (or Trojan)** is a malware program that appears to perform some useful task, but which also does something with negative consequences (e.g., launches a keylogger).
- Trojan horses can be installed as part of the payload of other malware but are often installed by a user or administrator, either deliberately or accidentally.



Examples: Trojan

- The AIDS Trojan:
  - 1989 through distributing floppy disk.
  - Encrypted hard drive, Ransomware
- False IE upgrade
  - Sent exe file to upgrade Inter Explorer
  - People learnt not to download exe file and run it
- False Anti-virus
- Back Orfice:
  - Provided access to remote machine, a service to Windows
  - Used as a backdoor to steal information
- Mocmex:
  - A trojan in Digital photo frame
  - When plugged into Windows Machine, it attacked MS windows

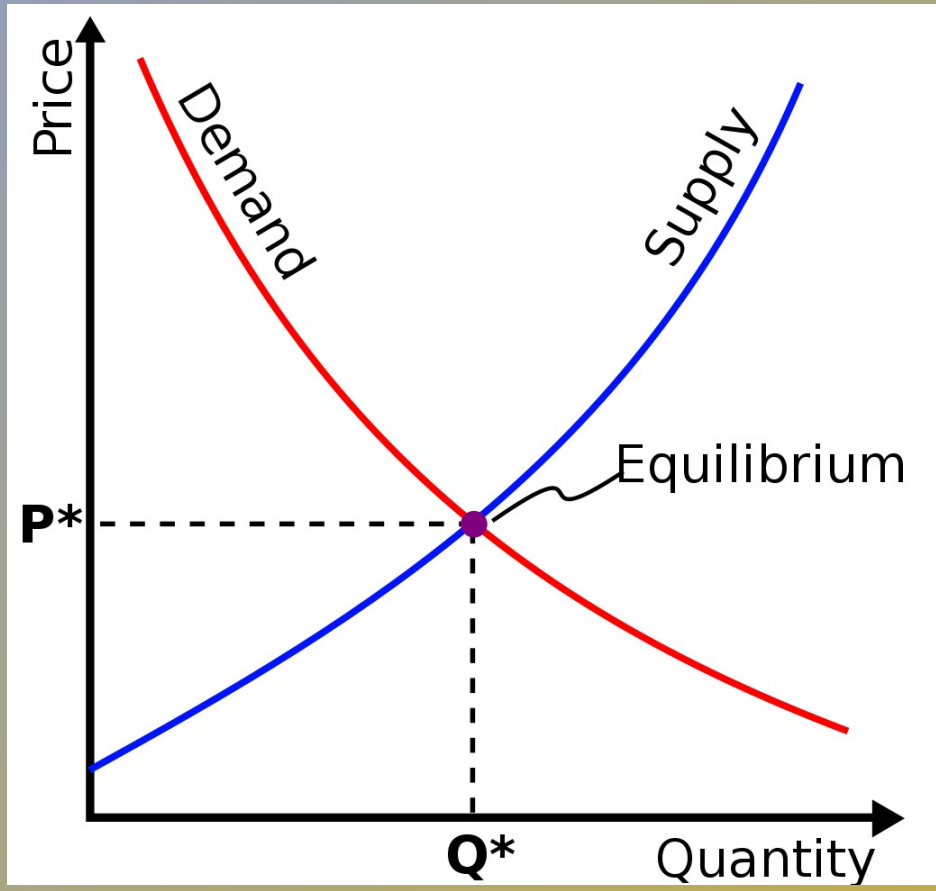
Economics of Malware

- Number of new threats per year appears to be growing an exponential rate.



Professional Malware

- Growth in professional cybercrime and online fraud has led to demand for professionally developed malware
- New malware is often a custom-designed variations of known exploits, so the malware designer can sell different “products” to his/her customers.
- Like every product, professional malware is subject to the laws of supply and demand.



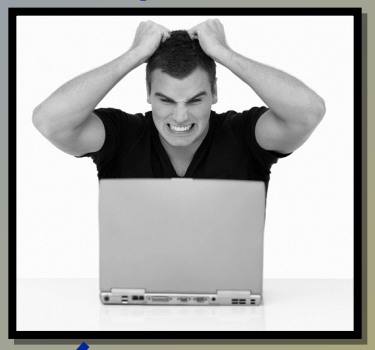
Adware

Adware software payload



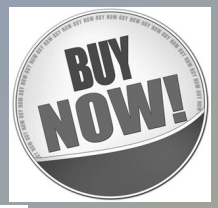
Adware engine infects a user's computer

Computer user



Adware engine requests advertisements from adware agent

Advertisers contract with adware agent for content





Advertisers



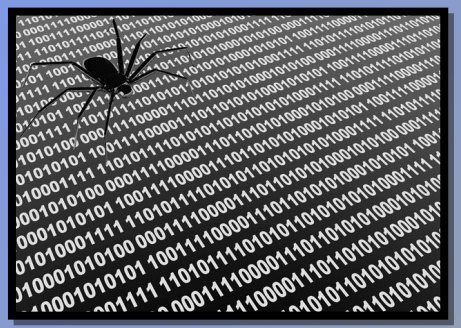
Adware agent



Adware agent delivers ad content to user

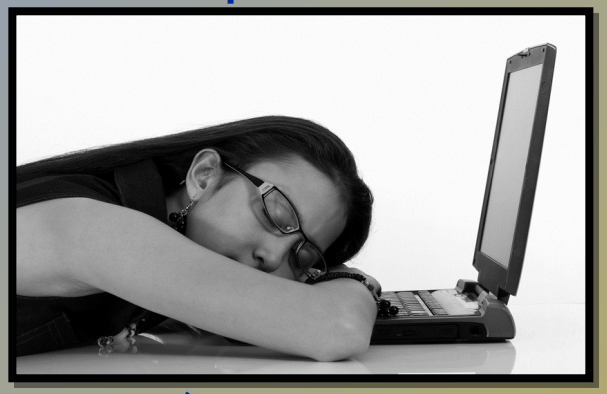
Spyware

Spyware software payload



1. Spyware engine infects a user's computer.

Computer user



2. Spyware process collects keystrokes, passwords, and screen captures.

3. Spyware process periodically sends collected data to spyware data collection agent.



Spyware data collection agent

Counter Measures

Signatures: A Malware Countermeasure

- Scan compare the analyzed object with a database of signatures
- A signature is a virus fingerprint
  - A string with a sequence of instructions specific for each virus
  - Different from a digital signature
- A file is infected if there is a signature inside its code
  - Fast pattern matching techniques to search for signatures
- All the signatures together create the malware database that usually is proprietary

White/Black Listing

- Maintain database of cryptographic hashes for
  - Operating system files
  - Popular applications
  - Known infected files
- Compute hash of each file in hard drives
- Look up into database to compare
- Needs to protect the integrity of the database
- Example: TripWire software

Heuristic Analysis

- Useful to identify new and “zero day” malware
- Code analysis (Static)
  - Based on the instructions, the antivirus can determine whether or not the program is malicious, i.e., program contains instruction to delete system files
- Execution emulation (Dynamic)
  - Run code in isolated emulation environment
    - Such as in Virtual Machine
  - Monitor actions that target file takes
  - If the actions are harmful, mark as virus
- Heuristic methods can trigger false alarms

Static vs. Dynamic Analysis

Static Analysis

- Checks the code without trying to execute it
- Quick scan in white list
- Filtering: scan with different antivirus and check if they return same result with different name
- Weeding: remove the correct part of files as junk to better identify the virus
- Code analysis: check binary code to understand if it is an executable, e.g., PE
- Disassembling: check if the byte code shows something unusual

Dynamic Analysis

- Check the execution of codes inside a virtual sandbox
- Monitor
  - File changes
  - Registry changes
  - Processes and threads
  - Networks ports

Online vs Offline Anti Virus Software

Online

- Free browser plug-in
- Scan needs internet connection
- No shielding
- Software and signatures update at each scan
- Poorly configurable
- Report collected by the company that offers the service

Offline

- Paid annual subscription
- Installed on the OS
- Software distributed securely by the vendor online or a retailer
- System shielding
- Scheduled software and signatures updates
- Scan without internet connection
- Report collected locally and may be sent to vendor

Quarantine

- A suspicious file can be isolated in a folder called quarantine:
  - E.g,. if the result of the heuristic analysis is positive and you are waiting for db signatures update
- The suspicious file is not deleted but made harmless: the user can decide when to remove it or eventually restore for a false positive
  - Interacting with a file in quarantine it is possible only through the antivirus program
- The file in quarantine is harmless because it is encrypted
- Usually the quarantine technique is proprietary and the details are kept secret